COMPTIA SECURITY+ SY0-701 DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.6 · Identity & Access Management

Mestre CyberSec · **Lesson 4.6 — Identity & Access Management** (12:46) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: IAM: account provisioning (create/config); RBAC (por função) e ABAC (por atributo); SSO (login único federado — SAML/OIDC); service account (credencial de script — gestão especial).

💡 Key Exam Highlights & Critical Concepts

- RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar
- SSO: login único — reduz reuso de senha (mais seguro)

🎯 Exam Tips & Typical CompTIA Scenarios

- 'access assigned based on job role'=RBAC

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.6 — Identity & Access Management)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Identity and Access Management (IAM)

Framework of policies and technologies that ensures the right users have appropriate access to resources; includes identification, authentication, authorization, and accounting.

⚠ ***Exam Trap:*** *Na prova, IAM engloba provisionamento, autenticação, autorização e contas; não confunda com um protocolo específico como SAML ou OIDC.*

• Account Provisioning (N/A)

Process of creating, configuring, and granting access to user accounts, typically during onboarding or role changes.

⚠ ***Exam Trap:*** *Provisionamento = criar/configurar conta e acessos; desprovisionamento = remover acesso. A prova pode associar ao princípio do menor privilégio.*

• Role-Based Access Control (RBAC)

Access control model where permissions are assigned to roles, and users receive access by being placed in the appropriate job role.

⚠ ***Exam Trap:*** *Gatilho: 'access assigned based on job role' = RBAC. Não confunda com ABAC, que usa atributos individuais e contextuais.*

• Attribute-Based Access Control (ABAC)

Access control model that grants or denies access based on attributes of the user, resource, action, and environment.

⚠ ***Exam Trap:*** *ABAC é mais granular e dinâmico que RBAC; envolve condições como departamento, hora, local e tipo de dispositivo.*

• Single Sign-On (SSO)

Authentication method that allows a user to log in once and access multiple applications or services without re-entering credentials.

⚠ ***Exam Trap:*** *SSO reduz reuso de senha e melhora segurança/UX; na prova, login único federado pode usar SAML ou OIDC.*

• Security Assertion Markup Language (SAML)

XML-based standard used to exchange authentication and authorization assertions between an identity provider and a service provider, commonly for enterprise SSO.

⚠️ ***Exam Trap:*** *SAML = SSO federado corporativo com XML/asserções e IdP/SP. Se a questão citar XML e navegador web, pense SAML.*

• OpenID Connect (OIDC)

Authentication layer built on OAuth 2.0 that uses JSON Web Tokens (JWT) to verify user identity and enable SSO for web, mobile, and API scenarios.

⚠️ ***Exam Trap:*** *OIDC = autenticação sobre OAuth 2.0 com JWT/JSON; mais moderno para apps web/mobile. Não é o mesmo que OAuth, que é autorização.*

• Service Account (N/A)

Non-human account used by an application, script, or service to access resources; it requires special credential management, least privilege, and rotation.

⚠️ ***Exam Trap:*** *Conta de serviço não é para login humano; a prova pode cobrar gestão especial de credenciais, rotação e menor privilégio.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Identity Federation & Single Sign-On (SSO) - The International Passport

🏠 **Real-World Analogy:** Consider an international biometric passport. Rather than applying for a localized citizen ID in every foreign country you visit (creating disparate usernames and passwords across distinct cloud SaaS apps), your home government issues an authoritative passport (Identity Provider - IdP). When arriving at a foreign border checkpoint (Service Provider - SP), border police inspect the cryptographically signed passport, trust your home nation's verification, and grant entry without requiring local registration.

🔍 **Root Cause & Background:** The enterprise SaaS explosion triggered severe user password fatigue, driving workers to reuse vulnerable credentials across dozens of portals or transcribe them onto insecure sticky notes.

🛡️ **GRC Auditor Perspective:** Auditing automated identity provisioning/deprovisioning via SCIM; verifying that terminating an employee account in the central IdP immediately revokes active sessions across all federated SaaS applications.

⚠️ **How CompTIA Tests This:** Exam trigger: 'permits users to authenticate once and access multiple independent cloud services across domain boundaries' = Identity Federation / SSO. 'System verifying credentials and asserting user identity' = Identity Provider (IdP).

📌 SAML 2.0 - The Notarized XML Corporate Dispatch

🏠 **Real-World Analogy:** SAML 2.0 is a notarized corporate declaration printed on security parchment and embossed with a certified wax seal sent by a trusted central notary (IdP) to an external enterprise building (SP). The letter formally asserts: 'We certify that employee Carlos successfully authenticated at headquarters with password and biometric tokens at 09:00 and holds the role of Chief Financial Officer'. The receiving gatekeeper verifies the notary's public certificate and grants entry.

🔍 **Root Cause & Background:** Enterprises required a secure, browser-mediated standard to establish federated trust relationships across business-to-business web applications without exposing raw password hashes to external providers.

🛡️ **GRC Auditor Perspective:** Auditing expiration dates of SAML signing X.509 certificates (preventing enterprise SSO blackouts); enforcing short assertion lifetimes; and validating assertion encryption to prevent token theft.

⚠️ **How CompTIA Tests This:** Exam trigger: 'XML-based framework designed for enterprise browser-based Single Sign-On across business domains' = SAML 2.0. Distractor trap: SAML relies on XML; OIDC relies on JSON/JWT.

📌 OAuth 2.0 - The Valet Key (Authorization Delegation)

🏠 **Real-World Analogy:** The valet key of an executive automobile. When dining out, you do not hand the parking attendant your master key, which opens the glove box containing jewelry and the trunk storing sensitive contracts; you hand them a valet key engineered exclusively to start the ignition and drive 15 mph. OAuth 2.0 delegates scoped resource access: granting a third-party app an access token to read contacts without ever exposing your master account password.

🔍 **Root Cause & Background:** Legacy integrations forced users to disclose their root credentials to external third-party software, meaning a compromise of a minor utility instantly leaked master credentials across the whole ecosystem.

🛡️ **GRC Auditor Perspective:** Auditing application consent permissions and OAuth token scopes in the enterprise identity tenant; revoking unused third-party grants; and requiring Authorization Code Flow with PKCE.

⚠️ **How CompTIA Tests This:** Exam trigger: 'open standard designed explicitly for scoped authorization delegation without sharing passwords' = OAuth 2.0. SUPREME EXAM TRAP: OAuth 2.0 is an AUTHORIZATION protocol, NOT authentication!

📌 OpenID Connect (OIDC) - The Photo ID Badge Over the Valet Key

🏠 **Real-World Analogy:** If OAuth 2.0 is the valet key authorizing car operation, OpenID Connect (OIDC) is the government driver's license clipped to the key ring. OIDC layers an AUTHENTICATION tier directly on top of OAuth 2.0, returning a cryptographically verifiable identity credential known as an ID Token (formatted as a JSON Web Token - JWT) proving who is behind the wheel.

🔍 **Root Cause & Background:** Developers attempted bespoke, insecure hacks to adapt OAuth 2.0 for user authentication, prompting the industry to standardize OIDC to provide robust identity verification via lightweight JSON Web Tokens.

🛡️ **GRC Auditor Perspective:** Enforcing mandatory claim validation (issuer, audience, expiration) on ID Tokens across internal APIs; auditing cryptographic verification of JWT signatures via authoritative jwks_uri endpoints.

⚠️ **How CompTIA Tests This:** Exam trigger: 'authentication layer built on top of OAuth 2.0 using JSON Web Tokens (JWT) for modern web and mobile single sign-on' = OpenID Connect (OIDC). Rule of thumb: OAuth = Authorization; OIDC = Authentication.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Mechanism permitting a user to log in once and gain authorized access to multiple independent enterprise applications	**Single Sign-On (SSO)**
XML-based open framework used primarily for corporate web browser Single Sign-On and enterprise identity federation	**SAML 2.0**
Security standard architected for authorization delegation using scoped access tokens without sharing account credentials	**OAuth 2.0**
Modern authentication standard layered on OAuth 2.0 employing JSON Web Tokens (JWT) for user identity verification	**OpenID Connect (OIDC)**
Authoritative entity in identity federation responsible for verifying user credentials and issuing signed tokens	**Identity Provider (IdP)**
External application or SaaS resource relying on assertions from an Identity Provider to grant system access	**Service Provider (SP / Relying Party)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A junior system administrator has been tasked with onboarding 15 new developers who will join the engineering team next Monday. The security manager wants to ensure each developer receives only the access necessary for their job function, that a formal record of granted permissions exists, and that the process is repeatable for every future hire. Which IAM process best addresses all of these needs?

A) Manual account creation on each system with personalized permissions assigned by the help desk

B) Sharing a single generic engineering account with all new developers via a shared password vault

C) Implementing an automated account provisioning workflow integrated with the HR system

D) Creating accounts with full access and removing permissions later as managers submit complaints

QUESTION 2 · EXAM SCENARIO

A healthcare organization is designing an access control model where each nurse must have permissions based on the specific ward they work in, the shift they are assigned to, and their seniority level. Permissions must dynamically change based on these contextual attributes, not just a static job title. Which access control model is most appropriate for this requirement?

A) Attribute-Based Access Control (ABAC) with policy-based evaluation

B) Mandatory Access Control (MAC) using security labels to eliminate single points of operational failure

C) Role-Based Access Control (RBAC) with predefined nursing roles across all hybrid on-premises and cloud clusters

D) Discretionary Access Control (DAC) where managers grant access individually

QUESTION 3 · EXAM SCENARIO

After a security audit, the company discovers that a terminated employee's account remained active for three weeks after departure, and during that window, sensitive customer data was exfiltrated using those credentials. The CISO wants to prevent this from ever happening again. Which IAM control should be implemented as the primary mitigation?

A) Implement mandatory 30-day password rotation for all user accounts

B) Integrate HR offboarding events with automated account deprovisioning

C) Require multi-factor authentication on every system in the organization

D) Block all outbound traffic from user accounts during business hours

QUESTION 4 · EXAM SCENARIO

An organization uses more than 40 cloud-based SaaS applications (Salesforce, Workday, GitHub, Jira, etc.) and users complain about managing dozens of different passwords. The security team also reports password reuse and weak passwords being created by frustrated employees. The CIO has approved a project to let users authenticate once and gain access to all approved applications. Which technology should the architect recommend?

A) Implement a centralized RADIUS server for all cloud applications

B) Require all users to use the same complex password across all platforms

C) Create a shared spreadsheet of application credentials in a restricted folder

D) Deploy a Single Sign-On (SSO) solution using SAML or OIDC federation

QUESTION 5 · EXAM SCENARIO

A development team has built a Python script that runs nightly to pull sales data from the CRM API and load it into the data warehouse. The credentials are currently hardcoded in the script source file, which is stored in a Git repository. A junior developer recently accidentally pushed the file to a public GitHub repository, exposing the API key. Which solution best addresses the underlying credential management problem for service accounts like this one?

A) Store the service account credential in a secrets management vault and retrieve it at runtime

B) Email the script credentials to all developers so they can rotate them manually each week

C) Encrypt the script with a password and share the password verbally during team meetings through automated configuration orchestration pipelines

D) Disable the API key permanently and stop the nightly data synchronization job while ensuring strict audit log retention compliance

QUESTION 6 · EXAM SCENARIO

The security architect is designing access control for a financial application. There are exactly 12 distinct job functions in the company (Teller, Branch Manager, Auditor, IT Admin, etc.), and each function has a well-defined, fixed set of permissions. Permissions change only when someone changes job roles, not based on contextual data. Which model is the best fit and why?

A) Attribute-Based Access Control (ABAC), because attributes provide the most flexibility to enforce least privilege and reduce attack surfaces

B) Rule-Based Access Control using firewall-style ACLs at the application layer through automated configuration orchestration pipelines

C) Role-Based Access Control (RBAC), because permissions align cleanly with static job functions

D) Mandatory Access Control (MAC), because financial data requires classification labels using standardized security content automation profiles

QUESTION 7 · EXAM SCENARIO

An organization wants to enable SSO between its on-premises Active Directory and several cloud SaaS applications. The architect needs a federation protocol that supports XML-based assertions, can exchange authentication and authorization data between the Identity Provider (ADFS) and the Service Providers (SaaS apps), and is widely supported in enterprise environments. Which protocol best meets these requirements?

A) LDAP (Lightweight Directory Access Protocol) over TLS

B) Kerberos authentication with ticket-granting tickets

C) NTLM (NT LAN Manager) with pass-through authentication

D) SAML 2.0 (Security Assertion Markup Language)

QUESTION 8 · EXAM SCENARIO

A mobile application development team wants to add SSO so users can log in with their existing Google or Apple accounts instead of creating new credentials. They need a modern protocol built on top of OAuth 2.0 that provides an identity layer with user profile information (email, name, profile picture) returned in a standardized JSON Web Token (JWT). Which protocol should be implemented?

A) RADIUS (Remote Authentication Dial-In User Service)

B) OpenID Connect (OIDC) layered on top of OAuth 2.0

C) SAML 2.0 with XML assertions transmitted via browser redirects

D) PAP (Password Authentication Protocol) with challenge-response

QUESTION 9 · EXAM SCENARIO

The security operations team detects that a service account used by a backup application has been making unusual network connections to an external IP address at 3 AM every night. Investigation reveals the service account password has not been rotated in three years and is stored in plaintext in a configuration file on 12 different servers. Which combination of controls should be implemented to address the root cause?

A) Implement credential vaulting, enforce automatic rotation, and apply least privilege to the service account

B) Disable the service account and migrate the backup job to run interactively under a personal admin account

C) Block all outbound traffic on port 443 at the perimeter firewall during business hours across all managed enterprise endpoints

D) Rename the service account and update the configuration file on all 12 servers manually while maintaining continuous telemetry and monitoring

QUESTION 10 · EXAM SCENARIO

A government contractor is implementing a fine-grained access control system where access to classified documents depends on the user's clearance level, the document's classification, the user's department, the time of day, and whether the access is from an approved device. The system must evaluate all these factors together before granting access. Which access control model is being described?

A) Simple Role-Based Access Control (RBAC) using only job titles to prevent unauthorized configuration drift across nodes

B) Mandatory Access Control (MAC) with only clearance and classification labels across all managed enterprise endpoints

C) Discretionary Access Control (DAC) managed by document owners individually while maintaining continuous telemetry and monitoring

D) Attribute-Based Access Control (ABAC) with multiple evaluated attributes and policies

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Implementing an automated account provisioning workflow integrated with the HR system

Automated account provisioning integrated with the HR system is the correct answer because it ensures consistent, repeatable, and auditable creation of accounts based on role templates (least privilege), automatically creates a formal record of granted permissions, and reduces human error. Manual creation (option A) is error-prone and non-scalable; shared accounts (option C) destroy accountability; over-provisioning (option D) violates least privilege and creates a major security risk.

Question 2: Option A — Attribute-Based Access Control (ABAC) with policy-based evaluation

Attribute-Based Access Control (ABAC) is correct because it evaluates multiple attributes (ward, shift, seniority) dynamically against policies to make access decisions. ABAC supports fine-grained, context-aware authorization that can adapt to complex scenarios. RBAC (option B) would require creating hundreds of static roles for every combination, which is unmanageable. MAC (option A) uses classification labels (typical in government/military). DAC (option D) is owner-controlled and inappropriate for regulated environments like healthcare.

Question 3: Option B — Integrate HR offboarding events with automated account deprovisioning

Automated deprovisioning tied to HR offboarding events is the primary mitigation because it ensures accounts are disabled immediately upon termination, closing the window of opportunity for misuse. The scenario specifically describes a stale, post-termination account being abused. Password rotation (option A) does not disable accounts; MFA (option C) would not have prevented use of the still-active account since the credentials were valid; traffic blocking (option D) is a network control that does not address identity lifecycle.

Question 4: Option D — Deploy a Single Sign-On (SSO) solution using SAML or OIDC federation

Single Sign-On (SSO) using SAML or OIDC federation is correct because it allows users to authenticate once at a central Identity Provider (IdP) and then access multiple federated applications without re-entering credentials. This eliminates password fatigue, reduces helpdesk costs, and improves security posture. RADIUS (option A) is for network access authentication, not SaaS federation. Same password across platforms (option C) is a serious security anti-pattern. A shared spreadsheet (option D) destroys confidentiality and accountability.

Question 5: Option A — Store the service account credential in a secrets management vault and retrieve it at runtime

Storing the service account credential in a secrets management vault (HashiCorp Vault, AWS Secrets Manager, Azure Key Vault) and retrieving it at runtime is the correct solution because it eliminates hardcoded credentials, supports automatic rotation, provides access auditing, and prevents plaintext exposure in source control. Emailing credentials (option A) is insecure and non-scalable. Encrypting scripts (option C) still requires secret distribution and does not solve the root cause. Disabling the job (option D) abandons the business requirement.

Question 6: Option C — Role-Based Access Control (RBAC), because permissions align cleanly with static job functions

Role-Based Access Control (RBAC) is the best fit because the scenario describes a small, well-defined set of static job functions with fixed permission sets that change only when roles change. RBAC excels in this type of environment: simple to manage, easy to audit, and aligns perfectly with organizational structure. ABAC (option A) is overkill when there are no contextual attributes to evaluate. Rule-based ACLs (option B) operate at network layers, not identity layers. MAC (option D) is for classified government environments, not typical commercial finance.

Question 7: Option D — SAML 2.0 (Security Assertion Markup Language)

SAML 2.0 is the correct answer because it is an XML-based federation standard explicitly designed to exchange authentication and authorization assertions between an Identity Provider and Service Providers, and it is the dominant federation protocol in enterprise SaaS integrations. LDAP (option A) is a directory access protocol, not a federation/authentication assertion protocol. Kerberos (option C) is excellent for on-premises but is not a federation protocol for cloud SaaS. NTLM (option D) is an outdated, insecure authentication protocol.

Question 8: Option B — OpenID Connect (OIDC) layered on top of OAuth 2.0

OpenID Connect (OIDC) is correct because it is a modern identity layer built on top of OAuth 2.0, returning standardized JWT ID tokens containing user profile claims (email, name, picture). It is the de facto standard for consumer-grade SSO (Google, Apple, Microsoft accounts) and modern web/mobile apps. RADIUS (option A) is for network access. SAML 2.0 (option B) uses XML and is more common in enterprise federation, not optimized for mobile/consumer identity. PAP (option D) is an obsolete, insecure authentication protocol.

Question 9: Option A — Implement credential vaulting, enforce automatic rotation, and apply least privilege to the service account

Credential vaulting (e.g., AWS Secrets Manager, HashiCorp Vault), automatic rotation, and least privilege are the correct combination because they directly address the root causes: plaintext storage, no rotation, and likely excessive permissions. These controls are the standard for secure service account management. Disabling and migrating to personal accounts (option A) destroys accountability. Blocking traffic (option C) is a band-aid that doesn't fix the credential issue. Manual rename (option D) does not fix the storage or rotation problem and is operationally fragile.

Question 10: Option D — Attribute-Based Access Control (ABAC) with multiple evaluated attributes and policies

Attribute-Based Access Control (ABAC) is correct because it evaluates multiple attributes (clearance, classification, department, time, device) against policies to make context-aware access decisions. ABAC supports the complex, multi-factor evaluation described in the scenario. Pure RBAC (option A) cannot consider time or device context. MAC (option B) typically uses only clearance and classification, not department/time/device. DAC (option D) is owner-controlled and would not enforce these centralized, multi-factor policies.